

Draft - SDAIA Cross-Border Risk Assessment (Anthropic Transfer)

Draft - SDAIA Cross-Border Risk Assessment (Anthropic Transfer)

Status: skeleton only. Source: HUMAN_CONFIRMATION_NEEDED.md G12 - SDAIA's "Risk Assessment Guideline for Transferring Personal Data Outside the Kingdom" (Feb 2025) plus the self-assessment tool at dgp.sdaia.gov.sa. Mandatory here because Taweed relies on an Appropriate Safeguard (SCC) and the transfer involves sensitive/health data - both triggers are hit, no derogation applies.

Recommended first step for counsel: run the actual dgp.sdaia.gov.sa self-assessment tool directly rather than treating this file as a substitute - this draft exists to pre-fill the factual inputs that tool will ask for, not to replace it.

1. Transfer description

Same as 01-scc-controller-to-processor.md §2 - data exporter, importer (Anthropic), categories of data subjects/data, purpose, duration, frequency. Don't duplicate-drift; keep both files in sync if either changes.

2. Legal basis for the transfer

Appropriate Safeguard (Saudi SCC - Controller-to-Processor form), since no SDAIA adequacy list exists for the destination country (G11) and Binding Common Rules doesn't cover third-party vendors like Anthropic.

3. Risk factors to assess

[COUNSEL/DPO TO SCORE - this is a judgment exercise the guideline's tool structures, not something to pre-answer without their input]:

Factor	Relevant fact on file	Assessment
Sensitivity of data	Health/claims data - PDPL's "sensitive data" category	[COUNSEL TO SCORE]
Destination country's legal regime	US - no SDAIA adequacy finding exists for any country; assess US surveillance-law exposure (e.g. FISA 702) as part of the standard risk-assessment factors the guideline asks about	[COUNSEL TO SCORE]
Importer's safeguards	Anthropic's stated security/access-control posture - see 01's open items, needs current documentation	[COUNSEL TO SCORE]
Volume/frequency	Ongoing, per-transaction, scales with clinic count	[COUNSEL TO SCORE]
Necessity/proportionality	Is the full data sent necessary for the AI feature, or could it be minimized/pseudonymized further before leaving the Kingdom? - worth an engineering conversation alongside the legal one	[COUNSEL + ENGINEERING TO ASSESS]
Availability of in-Kingdom alternative	A self-hosted, in-Kingdom LLM alternative exists as a documented contingency (docs/05_open_source_switching.md) but is not yet built/proven - relevant context for the risk assessment, not a mitigation already in place	Noted, not yet actionable

4. Mitigations already in place (engineering-side)

- data_origin synthetic/production gate already prevents real PHI from reaching any AI feature until this compliance work (this file included) is actually finished (per G5/BLK-AI-1) - this is a real, already-built control, not a proposed one.

- inference_geo="us" is a single, auditable pin point in packages/ai/src/anthropic-1p.ts - there's no scattered/implicit cross-border logic to audit, the transfer happens at one well-defined code path.

5. Determination and sign-off

[COUNSEL TO COMPLETE] - overall risk rating, any additional mitigations required before the transfer may proceed, and formal sign-off record (this is what actually satisfies the mandatory obligation - the assessment must be *performed and documented*, not just theoretically possible).

Open items before this can be finalized

1. Run the actual dgp.sdaia.gov.sa tool - confirm whether its output format supersedes or supplements this document.
2. Resolve 04-controller-processor-determination.md - affects who is the accountable party filing this assessment.
3. Get current Anthropic security/subprocessor documentation (same ask as 01).